

وثيقة استراتيجية

الأمن السيبراني

منظمي

نوع الوثيقة

وثيقة استراتيجية

القطاع

حكومي

التصنيف

سري

الإصدار

1.0

الحالة

مسودة

تاريخ الإعداد

17 June 2026

بطاقة ضبط الوثيقة

المنظمة
منظمتي
القطاع
حكومي
المجال
الأمن السيبراني
نوع الوثيقة
وثيقة استراتيجية
التصنيف
سري
الإصدار
1.0
الحالة
مسودة
تاريخ الإعداد
17 June 2026
أعد بواسطة
Mizan GRC Platform

المحتويات

1	الملخص التنفيذي
2	النطاق والأطر المرجعية المعتمدة
3	المنهجية
4	ملخص الوضع الراهن ومستوى النضج
5	الرؤية والأهداف الاستراتيجية
6	الركائز الاستراتيجية
7	البيئة التنظيمية والتحديات
8	تحليل الفجوات
9	خارطة الطريق التنفيذية
10	مؤشرات الأداء الرئيسية
11	تقييم الثقة والمخاطر
12	نموذج الحوكمة والمسؤوليات
13	مصفوفة تتبع الأطر المرجعية
14	الملاحق

هذه الوثيقة سرية ومعدة حصراً للاستخدام الداخلي. جميع التوصيات مبنية على بيانات التشخيص المقدمة.

الملخص التنفيذي

الغرض	الأمن السيبراني المعدة لمنظمتي (القطاع: حكومي)، مبنية على تحليل تشخيصي كامل ومواءمة مع 2 من الأطر المرجعية تقدم هذه الوثيقة استراتيجية المختارة ((NCA ECC, NCA DCC (NCA ECC (Essential Cybersecurity Controls), NCA DCC (Data Cybersecurity Controls)).
الأطر المرجعية	NCA ECC (Essential Cybersecurity Controls) — NCA DCC (Data Cybersecurity Controls)
أبرز الأولويات	وتعيين CISO؛ تشغيل SOC و SIEM؛ تطبيق IAM/PAM/MFA؛ تأسيس CSIRT وخطط الاستجابة؛ برنامج إدارة تأسيس إدارة الأمن السيبراني الثغرات
أبرز الفجوات	حوكمة الأمن السيبراني؛ غياب مركز العمليات الأمنية SOC وأدوات SIEM؛ قصور إدارة الهوية والوصول IAM وغياب غياب وظيفة CISO وهيكل غياب فريق الاستجابة للحوادث CSIRT وخطة الاستجابة الرسمية؛ ضعف إدارة الثغرات الأمنية وغياب منع تسرب المصادقة متعددة العوامل MFA؛ البيانات DLP وضوابط الوصول عن البعد
أفق التنفيذ	24 شهر
درجة الثقة	78%
المخاطر الرئيسية	الرسمية لأمن المعلومات؛ ضعف التحكم في الوصول وغياب المصادقة متعددة العوامل؛ انعدام قدرة الكشف والاستجابة غياب سياسات الحوكمة للحوادث؛ التعرض لهجمات التصيد الاحتيالي وبرمجيات الفدية؛ الثغرات الأمنية في بيئة الجهات الخارجية والموردين

النطاق والأطر المرجعية المعتمدة

NCA ECC (Essential Cybersecurity Controls) (ECC)

يعكس هذا الإطار في الاستراتيجية عبر مجالات: الحوكمة، إدارة الهوية، مركز العمليات الأمنية، الاستجابة للحوادث، إدارة الثغرات.

NCA DCC (Data Cybersecurity Controls) (DCC)

يعكس هذا الإطار في الاستراتيجية عبر مجالات: تصنيف البيانات، التشفير، DLP، البيانات الحساسة، حماية البيانات.

المنهجية

المرحلة 1 – تحليل المدخلات التشخيصية

مراجعة منهجية للبيانات التشخيصية المدخلة من المنظمة (القطاع، الحجم، النضج الحالي، الأنظمة، التحديات) وتأكيد جودة المدخلات قبل بدء أي تحليل.

المرحلة 2 – تحديد نطاق الأطر المرجعية

اعتماد الأطر التالية كنطاق رسمي للتحليل والمواءمة: NCA ECC (Essential Cybersecurity Controls), NCA DCC (Data Cybersecurity Controls), NCA ECC, NCA DCC.

المرحلة 3 – تحليل تغطية القدرات

مطابقة المدخلات والضوابط القائمة مع عائلات القدرات التي تتطلبها الأطر المختارة (الحوكمة، إدارة الهوية، المراقبة، الاستجابة، الوصول عن بعد، حماية البيانات...).

المرحلة 4 – تحليل الفجوات وترتيب الأولويات

استخراج الفجوات بين الوضع الحالي ومتطلبات الأطر، وترتيبها وفق الأثر والأولوية والقابلية للمعالجة.

المرحلة 5 – تصميم خارطة الطريق والمؤشرات

بناء خارطة طريق متعددة الموجات (قصيرة/متوسطة/طويلة المدى) مرتبطة بمؤشرات أداء (KPI) ومؤشرات مخاطر (KRI) قابلة للقياس.

المرحلة 6 – تقييم المخاطر والثقة

تقدير المخاطر التنفيذية ومخاطر التغيير، وحساب درجة ثقة شاملة في قابلية تنفيذ الاستراتيجية.

المرحلة 7 – التحقق وبوابات الجودة

اجتياز سلسلة بوابات التحقق: التحقق من المجال، كثافة المحتوى، تغطية الأطر، التدقيق الدلالي، ثم التدقيق النهائي قبل النشر.

ملخص الوضع الراهن ومستوى النضج

السياق التنظيمي: يفرض الإطار التنظيمي المطبق على منظمتي — وعلى رأسه متطلبات NCA ECC, NCA DCC المعمول بها في قطاع حكومي — التزامات محددة على حوكمة الأمن السيبراني، بما يشمل إثبات تطبيق الضوابط والحوكمة المستمرة وإعداد أدلة التدقيق وفق اللوائح والأنظمة السارية. وتشمل الأطر التنظيمية المختارة الملزمة لمنظمتي: NCA ECC، NCA DCC. إذ تكشف القدرات الأساسية عن فجوات يجب سدها قبل تحقيق أي التزام مستدام.

سياق التهديدات: تشير البيانات العامة لفرق الاستجابة الوطنية خلال آخر دورة تقرير إلى ارتفاع ملحوظ في حوادث اختراق سلاسل الإمداد، والتصيد الموجه، وحملات برامج الفدية — مما يرفع أولوية تحصين ضوابط الأمن السيبراني لدى منظمتي وتسريع النضج التشغيلي في الاستجابة للحوادث.

الرؤية والأهداف الاستراتيجية

إنشاء إدارة متخصصة للأمن السيبراني وتعيين CISO وتفعيل لجنة الحوكمة ونموذج التشغيل 1.

المستهدف القابل للقياس	إنجاز الهيكل التنظيمي بنسبة 100% وتعيين CISO مؤهل خلال الإطار المحدد
المبرر	ضرورة وجود هيكل تنظيمي متخصص لقيادة وإدارة برنامج الأمن السيبراني بفعالية
الإطار الزمني	6 أشهر

تعزيز حماية البيانات عبر التصنيف والتشفير و DLP 2.

المستهدف القابل للقياس	حماية 95% من البيانات الحساسة المصنفة
المبرر	تلبية متطلبات NCA DCC لحماية البيانات
الإطار الزمني	18 شهر

نشر برنامج إدارة الثغرات الأمنية على جميع الأصول الحيوية 3.

المستهدف القابل للقياس	تغطية 95% من الأصول المصنفة ضمن دورة مسح شهرية
المبرر	ضعف الرؤية على الثغرات الأمنية في البنية التحتية الحيوية
الإطار الزمني	12 شهرا

إطلاق برنامج التوعية بالأمن السيبراني لجميع الموظفين 4.

المستهدف القابل للقياس	معدل اجتياز 90% في التقييمات الدورية لمكافحة التصيد الاحتيالي
المبرر	ارتفاع معدل نجاح هجمات الهندسة الاجتماعية بسبب ضعف الوعي
الإطار الزمني	12 شهرا

إنشاء فريق الاستجابة للحوادث السيبرانية وفق متطلبات NCA ECC 5.

المستهدف القابل للقياس	استيفاء 100% من متطلبات CSIRT المحددة في NCA ECC
المبرر	غياب آلية استجابة رسمية تقلص أثر الحوادث السيبرانية
الإطار الزمني	12 شهرا

تأسيس قدرات الرصد والكشف عبر SOC و SIEM 6.

المستهدف القابل للقياس	تشغيل SOC مع تغطية SIEM للأصول الحرجة
المبرر	تقليل زمن الكشف عن الحوادث الأمنية
الإطار الزمني	12 شهر

تعزيز إدارة الهوية والوصول والصلاحيات المميزة 7.

المستهدف القابل للقياس	تطبيق MFA و PAM على الأنظمة والحسابات الحرجة
المبرر	تقليل مخاطر الوصول غير المصرح به
الإطار الزمني	12 شهر

بناء قدرات الاستجابة للحوادث عبر CSIRT 8.

المستهدف القابل للقياس	تشغيل CSIRT مع SLA للاستجابة للحوادث الحرجة
المبرر	احتواء الحوادث وتقليل الأثر التشغيلي
الإطار الزمني	12 شهر

الركائز الاستراتيجية

الوصف	2. الركائز الاستراتيجية حوكمة ونموذج التشغيل اعتماد وتحديث سياسات الحوكمة السيبرانية وفق NCA ECC. سياسات الحوكمة السيبرانية
الوصف	منصة حوكمة معتمدة ميثاق لجنة حوكمة أمن سيبراني معتمد مع اجتماعات ربع سنوية. لجنة حوكمة الأمن لجنة حوكمة فعالة
الوصف	توزيع مسؤوليات RACI للأمن السيبراني عبر الإدارات. مصفوفة RACI مصفوفة RACI معتمدة
الوصف	الحماية والكشف والاستجابة تشغيل المركز. تشغيل SOC/SIEM مركز SOC تشغيلي
الوصف	خطط الاستجابة. فريق CSIRT فريق CSIRT جاهز
الوصف	قواعد المراقبة. الرصد والمراقبة تغطية SIEM للأصول الحرجة
الوصف	الهوية وحماية البيانات ضوابط الهوية. IAM/PAM/MFA. تغطية MFA للحسابات الحرجة
الوصف	جرد وتصنيف. تصنيف البيانات سجل بيانات مصنف
الوصف	تفعيل DLP. DLP منصة DLP مفعلة - منع تسرب البيانات وفق ضوابط DCC
الوصف	المرونة واستمرارية الأعمال اختبار النسخ. النسخ الاحتياطي خطة نسخ احتياطي معتمدة
الوصف	اختبار DR. التعافي من الكوارث خطة DR مختبرة
الوصف	خطط BCP. استمرارية الأعمال خطط استمرارية معتمدة

البيئة التنظيمية والتهديدات

السياق التنظيمي: يفرض الإطار التنظيمي المطبق على منظمتي — وعلى رأسه متطلبات NCA ECC, NCA DCC المعمول بها في قطاع حكومي — التزامات محددة على حوكمة الأمن السيبراني، بما يشمل إثبات تطبيق الضوابط والحوكمة المستمرة وإعداد أدلة التدقيق وفق اللوائح والأنظمة السارية. وتشمل الأطر التنظيمية المختارة الملزمة لمنظمتي: NCA ECC، NCA DCC. إذ تكشف القدرات الأساسية عن فجوات يجب سدها قبل تحقيق أي التزام مستدام.

سياق التهديدات: تشير البيانات العامة لفرق الاستجابة الوطنية خلال آخر دورة تقرير إلى ارتفاع ملحوظ في حوادث اختراق سلاسل الإمداد، والتصيد الموجه، وحملات برامج الفدية — مما يرفع أولوية تحصين ضوابط الأمن السيبراني لدى منظمتي وتسريع النضج التشغيلي في الاستجابة للحوادث.

السياق التشغيلي وسياق الأعمال: يترتب على منظمتي موازنة متطلبات التحول الرقمي مع الحفاظ على استمرارية الأعمال والعمليات في قطاع حكومي، وضمان أن تواكب استثمارات الأمن السيبراني وتيرة توسع الخدمات والعمليات دون إحداث فجوات تدقيقية أو ضغط تشغيلي على الكوادر.

تطبيق الضوابط المرتبطة ومتابعتها	عالية	عال	تنظيمي	
تطبيق الضوابط المرتبطة ومتابعتها	عالية	عال	تهديد	
تطبيق الضوابط المرتبطة ومتابعتها	متوسطة	متوسط	أعمال	

تحليل الفجوات

1	وهيكل حوكمة الأمن السيبراني غياب وظيفة CISO	المعلومات، وتفتقر المنظمة إلى سياسات وإجراءات موثقة تغطي... لا توجد وظيفة رسمية لمسؤول أمن	حرجة	مفتوحة
2	الأمنية SOC وأدوات SIEM غياب مركز العمليات	أمنية فاعل ولا منصة لإدارة المعلومات الأمنية والأحداث، مما ي... لا تمتلك المنظمة مركز عمليات	حرجة	مفتوحة
3	المصادقة متعددة العوامل MFA إدارة الهوية والوصول IAM وغياب قصور	دون تطبيق MFA أو سياسات صلاحيات الحد الأدنى، وتفتقر... تعتمد المنظمة على بيانات اعتماد بسيطة	عالية	مفتوحة
4	CSIRT وخطة الاستجابة الرسمية غياب فريق الاستجابة للحوادث	السيبرانية مشكل رسمياً، ولا إجراءات موثقة لإدارة الحوادث... لا يوجد فريق استجابة للحوادث	عالية	مفتوحة
5	DLP وضوابط الوصول عن البعد الأمنية وغياب منع تسرب البيانات ضعف إدارة الثغرات	للثغرات الأمنية أو اختبار الاختراق، ولا تمتلك أدوات منع فقد... لا تجري المنظمة فحوصات دورية	عالية	مفتوحة

1

الإجراء	مسؤول أمن المعلومات CISO رسمياً وإصدار قرار تنظيمي بتحديد صلاحياته ومساره التقريري المباشر للقيادة العليا تحديد وتعيين
المسؤول	الرئيس التنفيذي / المدير العام
الإطار الزمني	الشهر 1
النتائج	قرار تعيين رسمي وهيكل تنظيمي معتمد

2

الإجراء	السيبراني يشمل السياسة العامة وسياسات فرعية تغطي متطلبات NCA ECC-1-1 كالتصنيف والمخاطر والامثال إعداد الإطار التنظيمي لحوكمة الأمن
المسؤول	Lead المسؤول أمن السيبراني / CISO
الإطار الزمني	الشهر 2-3
النتائج	حزمة سياسات أمن سيبراني موثقة ومعتمدة

3

الإجراء	توجيهية للأمن السيبراني تضم ممثلين من الوحدات التشغيلية الرئيسية مع تحديد دورية الاجتماعات وآليات الإبلاغ تشكيل لجنة
المسؤول	CISO
الإطار الزمني	الشهر 3
النتائج	ميثاق لجنة التوجيه الأمني ومحاضر اجتماعات دورية

4

الإجراء	تقييم نضج شامل مقابل متطلبات NCA ECC وNCA DCC وتوثيق خارطة طريق الامتثال بمؤشرات قياس واضحة إجراء
المسؤول	Lead المسؤول أمن السيبراني / CISO
الإطار الزمني	الشهر 4

الناتج	تقرير تقييم النضج وخارطة طريق الامتثال
5	
الإجراء	إطلاق برنامج التوعية بالأمن السيبراني للقيادة والموظفين مع قياس مستوى الوعي قبل وبعد البرنامج
المسؤول	Lead المسؤول أمن السيبراني / CISO
الإطار الزمني	الشهر 5-6
الناتج	تقرير مستوى الوعي ونسبة الإتمام
1	
الإجراء	مقابل الاستعانة بخدمة SOC مدارة MSSP وتحديد النموذج الملائم لحجم المنظمة الحكومية ومتطلبات NCA تقييم خيارات بناء SOC داخلي ECC-2-2
المسؤول	CISO / SOC Manager
الإطار الزمني	الشهر 1-2
الناتج	دراسة جدوى وقرار نموذج SOC المعتمد
2	
الإجراء	وجمع عروض الموردين المعتمدين لدى NCA وإجراء عملية اختيار مبنية على معايير التكامل ومتطلبات الامتثال تحديد متطلبات منصة SIEM
المسؤول	CISO / SOC Manager
الإطار الزمني	الشهر 2-3
الناتج	وثيقة متطلبات SIEM وقرار اختيار المورد
3	
الإجراء	وربطها بالمصادر الرئيسية للسجلات كجدران الحماية وأنظمة المصادقة والخوادم الحساسة وضبط قواعد الكشف الأولية تنفيذ نشر منصة SIEM
المسؤول	SOC Manager
الإطار الزمني	الشهر 4-6
الناتج	منصة SIEM فعالة مع تغطية مصادر البيانات الأساسية
4	
الإجراء	وسيناريوهات الكشف المصممة خصيصا للقطاع الحكومي والاشتراك في مصادر استخبارات التهديدات الوطنية تطوير قواعد استخبارات التهديدات
المسؤول	SOC Manager / CISO
الإطار الزمني	الشهر 6-8
الناتج	مكتبة قواعد الكشف وتقارير استخبارات التهديدات الدورية
5	
الإجراء	تأهيل وتدريب كوادر SOC وتوثيق إجراءات التشغيل القياسية لجميع سيناريوهات الحوادث المعرفة
المسؤول	SOC Manager
الإطار الزمني	الشهر 7-9
الناتج	فريق SOC مؤهل ودليل إجراءات التشغيل القياسية

1

الإجراء	المستخدمة بما فيها الحسابات المميزة والمشاركة وتوثيق مصفوفة الصلاحيات الحالية وتحديد الفجوات مقابل مبدأ إجراء مسح شامل لجميع الحسابات الحد الأدنى من الصلاحيات
المسؤول	Lead المسؤول أمن السيبراني / CISO
الإطار الزمني	الشهر 1
النتائج	مصفوفة صلاحيات موثقة وتقرير الفجوات

2

الإجراء	التحكم في الوصول المبنية على الأدوار RBAC وإلغاء الحسابات الزائدة والمشاركة وفرض معايير كلمات المرور القوية تصميم وتطبيق سياسة
المسؤول	CISO / SOC Manager
الإطار الزمني	الشهر 2-3
النتائج	سياسة RBAC مطبقة وتقرير تنظيف الحسابات

3

الإجراء	متعددة العوامل MFA على جميع الأنظمة الحيوية والبوابات الإدارية والوصول عن بعد بشكل متدرج حسب الأولوية نشر حل المصادقة
المسؤول	CISO / SOC Manager
الإطار الزمني	الشهر 3-5
النتائج	تغطية MFA على الأنظمة الحيوية بنسبة 100%

4

الإجراء	الحسابات المميزة PAM مع تفعيل جلسات مراقبة مسجلة لجميع أعمال المسؤولين وجدولة تدوير كلمات المرور تلقائياً تطبيق حل إدارة
المسؤول	SOC Manager / CISO
الإطار الزمني	الشهر 5-7
النتائج	منصة PAM فعالة مع سجلات جلسات المسؤولين

5

الإجراء	دورية ربع سنوية لصلاحيات الوصول وتوثيق نتائجها والإجراءات التصحيحية ضمن تقارير الامتثال لـ NCA ECC إجراء مراجعات
المسؤول	المسؤول أمن السيبراني Lead
الإطار الزمني	كل ربع سنة
النتائج	تقارير مراجعة الوصول الفصلية

1

الإجراء	CSIRT وتعيين أعضائه وتوثيق الأدوار والمسؤوليات وقنوات التواصل الداخلية والخارجية بما فيها التنسيق مع هيئة تحديد هيكل فريق الاستجابة للحوادث NCA
المسؤول	CISO
الإطار الزمني	الشهر 1-2
النتائج	ميثاق CSIRT ومصفوفة الأدوار والمسؤوليات

2

الإجراء	الشاملة التي تغطي مراحل الاحتواء والاستئصال والتعافي والإبلاغ مع تصنيف الحوادث وفق معايير NCA ECC-2-5 صياغة خطة الاستجابة للحوادث
المسؤول	CISO / SOC Manager
الإطار الزمني	الشهر 2-3
النتائج	خطة استجابة للحوادث موثقة ومعتمدة

3

الإجراء	الحوادث بال منصات الوطنية المعتمدة وتوثيق متطلبات الإبلاغ الإلزامي والإطار الزمني للإشعار وفق NCA DCC ربط آليات الإبلاغ عن
المسؤول	المسؤول أمن السبراني CISO / e Lead
الإطار الزمني	الشهر 3
النتائج	إجراءات الإبلاغ الوطني الموثقة والمختبرة

4

الإجراء	Tabletop Exercises بسيناريوهات تشمل برمجيات القدية واختراق البيانات والثغرات الصفرية وتوثيق الدروس تنفيذ تمارين محاكاة الحوادث الجدولية الاستفادة
المسؤول	SOC Manager / CISO
الإطار الزمني	الشهر 5-6
النتائج	تقارير التمارين والدروس المستفادة وتحديثات الخطة

5

الإجراء	وتحديث خطة الاستجابة للحوادث بعد كل تمرين أو حادثة فعلية وضمان توافقها مع التعديلات التنظيمية لـ NCA مراجعة
المسؤول	المسؤول أمن السبراني e Lead
الإطار الزمني	نصف سنوي
النتائج	نسخ محدثة من خطة الاستجابة للحوادث

1

الإجراء	وتصنيفها وفق حساسيتها ثم إجراء فحص أولي للثغرات الأمنية على جميع الأصول الحيوية باستخدام أداة فحص بناء سجل أصول المعلومات الشامل معتمدة
المسؤول	Lead المسؤول أمن السبراني CISO /
الإطار الزمني	الشهر 1-2
النتائج	سجل الأصول المصنفة وتقرير الفحص الأولي للثغرات

2

الإجراء	الدوري يحدد دورات الفحص الشهرية والفصلية وأولويات ال معالجة وإجراءات التحقق من الإصلاح مع ربط النتائج وضع برنامج إدارة الثغرات بمتطلبات NCA ECC-2-4
المسؤول	CISO / SOC Manager
الإطار الزمني	الشهر 2-3

الناتج	برنامج إدارة الثغرات وآلية تتبع ال معالجة
3	
الإجراء	السوي الشامل من طرف جهة مستقلة معتمدة لدى NCA وتوثيق النتائج وخطط ال معالجة وتقديمها لإدارة المنظمة تنفيذ اختبار الاختراق
المسؤول	CISO
الإطار الزمني	سنويا
الناتج	تقرير اختبار الاختراق وخطة ال معالجة المعتمدة
4	
الإجراء	DLP على نقاط النهاية والبريد الإلكتروني وبوابات الإنترنت لحماية البيانات الحكومية الحساسة وفق متطلبات NCA نشر حلول لمنع فقدان البيانات وضبط قواعد التصنيف DCC
المسؤول	CISO / SOC Manager
الإطار الزمني	الشهر 4-7
الناتج	منصة DLP فعالة مع تقارير رصد تسرب البيانات
5	
الإجراء	باستخدام تقنية VPN مشفرة مع MFA وسياسات انتهاء الجلسة التلقائي ومراجعة سجلات الوصول أسبوعيا لضمان تطبيق ضوابط الوصول عن بعد الآمن الامتثال لـ NCA ECC
المسؤول	Lead المسؤول أمن السبراني / SOC Manager
الإطار الزمني	الشهر 5-6
الناتج	سياسة وصول عن بعد مطبقة وتقارير مراجعة أسبوعية

خارطة الطريق التنفيذية

تأسيس إدارة الأمن السيبراني وتعيين CISO . المرحلة 1: تأسيس (1-6 أشهر)
المرحلة 1: تأسيس (1-6 أشهر) : المرحلة

1-6 أشهر: الفترة

تأسيس إدارة الأمن السيبراني وتعيين CISO : المبادرة
الإدارة العليا / CISO : المسؤول

هيكل CISO ولجنة حوكمة معتمدة : المخرج المتوقع
الإطار المرتبط : NCA ECC

تصنيف وجرد البيانات الحساسة . المرحلة 1: تأسيس (1-6 أشهر)
المرحلة 1: تأسيس (1-6 أشهر) : المرحلة

1-6 أشهر: الفترة

تصنيف وجرد البيانات الحساسة : المبادرة

مدير حماية البيانات : المسؤول

سجل بيانات مصنفة ومعتمد : المخرج المتوقع
الإطار المرتبط : NCA DCC

تفعيل لجنة حوكمة الأمن السيبراني . المرحلة 1: تأسيس (1-6 أشهر)
المرحلة 1: تأسيس (1-6 أشهر) : المرحلة

1-6 أشهر: الفترة

تفعيل لجنة حوكمة الأمن السيبراني : المبادرة

الإدارة العليا / CISO : المسؤول

ميثاق لجنة حوكمة ومصفوفة RACI معتمدة : المخرج المتوقع
الإطار المرتبط : NCA ECC

تشغيل SOC و SIEM . المرحلة 2: تمكين وتشغيل (7-18 شهر)
المرحلة 2: تمكين وتشغيل (7-18 شهر) : المرحلة

7-18 شهر: الفترة

تشغيل SOC و SIEM : المبادرة

مدير SOC : المسؤول

مركز SOC تشغيلي مع تغطية SIEM : المخرج المتوقع
الإطار المرتبط : NCA ECC

تطبيق IAM/PAM/MFA . المرحلة 2: تمكين وتشغيل (7-18 شهر)
المرحلة 2: تمكين وتشغيل (7-18 شهر) : المرحلة

7-18 شهر: الفترة

تطبيق IAM/PAM/MFA : المبادرة

مدير IAM/PAM : المسؤول

منصة IAM/PAM مع MFA للحسابات الحرجة : المخرج المتوقع
الإطار المرتبط : NCA ECC

تأسيس CSIRT وخطط الاستجابة . المرحلة 2: تمكين وتشغيل (7-18 شهر)
المرحلة 2: تمكين وتشغيل (7-18 شهر) : المرحلة

7-18 شهر: الفترة

تأسيس CSIRT وخطط الاستجابة : المبادرة

قائد CSIRT: المسؤول

فريق CSIRT وخطط استجابة معتمدة: المخرج المتوقع

NCA ECC: الإطار المرتبط

ضبط معالجة البيانات الحساسة: المرحلة 3: تحسين واستدامة (19-24 شهر)

المرحلة 3: تحسين واستدامة (19-24 شهر): المرحلة

19-24 شهر: الفترة

ضبط معالجة البيانات الحساسة: المبادرة

مسؤول حماية البيانات: المسؤول

إجراءات معالجة بيانات حساسة معتمدة: المخرج المتوقع

NCA DCC: الإطار المرتبط

تفعيل DLP ومراقبة تسرب البيانات: المرحلة 2: تمكين وتشغيل

المرحلة 2: تمكين وتشغيل: المرحلة

7-18 شهر: الفترة

تفعيل DLP ومراقبة تسرب البيانات: المبادرة

مدير حماية البيانات: المسؤول

منصة DLP وقواعد مراقبة تسرب البيانات مفعلة: المخرج المتوقع

NCA DCC: الإطار المرتبط

تطبيق ضوابط التشفير وإدارة المفاتيح: المرحلة 2: تمكين وتشغيل

المرحلة 2: تمكين وتشغيل: المرحلة

7-18 شهر: الفترة

تطبيق ضوابط التشفير وإدارة المفاتيح: المبادرة

مدير حماية البيانات: المسؤول

ضوابط تشفير وإدارة مفاتيح مطابقة: المخرج المتوقع

NCA DCC: الإطار المرتبط

مؤشرات الأداء الرئيسية

متوسط زمن اكتشاف الحوادث الأمنية

متوسط زمن اكتشاف الحوادث الأمنية: المؤشر

KPI: النوع

> 4 ساعات: القيمة المستهدفة

CISO: المالك

شهري: الإطار الزمني

متوسط زمن الاستجابة للحوادث (MTTR)

متوسط زمن الاستجابة للحوادث (MTTR): المؤشر

KPI: النوع

> 4 ساعات: القيمة المستهدفة

CISO: المالك

شهري: الإطار الزمني

نسبة إغلاق الثغرات الحرجة ضمن SLA

نسبة إغلاق الثغرات الحرجة ضمن SLA: المؤشر

KPI: النوع

95% خلال 72 ساعة: القيمة المستهدفة

CISO: المالك

شهري: الإطار الزمني

نسبة محاولات الدخول الفاشلة الشاذة

نسبة محاولات الدخول الفاشلة الشاذة: المؤشر

KPI: النوع

100%: القيمة المستهدفة

CISO: المالك

أسبوعي: الإطار الزمني

عدد حوادث تسرب البيانات الحرجة

عدد حوادث تسرب البيانات الحرجة: المؤشر

KRI: النوع

2 حوادث حرجة سنويا: القيمة المستهدفة

CISO: المالك

شهري: الإطار الزمني

نسبة تغطية التشفير للبيانات الحساسة

نسبة تغطية التشفير للبيانات الحساسة: المؤشر

KPI: النوع

95% أو 100% للبيانات الحساسة المصنفة: القيمة المستهدفة

CISO: المالك

ربع سنوي: الإطار الزمني

درجة مخاطر الأطراف الثالثة

درجة مخاطر الأطراف الثالثة: المؤشر

KRI: النوع

100%: القيمة المستهدفة

CISO: المالك

ربع سنوي: الإطار الزمني

نسبة الأصول المصنفة وفق ضوابط البيانات

نسبة الأصول المصنفة وفق ضوابط البيانات: المؤشر

KPI: النوع

95% أو 100% للبيانات الحساسة المصنفة: القيمة المستهدفة

CISO: المالك

ربع سنوي: الإطار الزمني

معدل فشل اختبارات التصيد الاحتيالي

معدل فشل اختبارات التصيد الاحتيالي: المؤشر

KRI: النوع

أقل من 5%: القيمة المستهدفة

CISO: المالك

ربع سنوي: الإطار الزمني

نسبة انعقاد لجنة حوكمة الأمن السيبراني وفق التواتر المعتمد

نسبة انعقاد لجنة حوكمة الأمن السيبراني وفق التواتر المعتمد: المؤشر

KPI: النوع

100%: القيمة المستهدفة

CISO: المالك

ربع سنوي: الإطار الزمني

متوسط زمن اكتشاف الحوادث الأمنية

متوسط زمن اكتشاف الحوادث الأمنية: المؤشر

مجموع أزمنة اكتشاف الحوادث / عدد الحوادث: الصيغة

SIEM / SOC: مصدر البيانات

متوسط زمن الاستجابة للحوادث (MTTR)

متوسط زمن الاستجابة للحوادث (MTTR): المؤشر

مجموع أزمنة الاستجابة للحوادث الحرجة / عدد الحوادث الحرجة: الصيغة

ITSM / SOAR / SIEM: مصدر البيانات

نسبة إغلاق الثغرات الحرجة ضمن SLA

نسبة إغلاق الثغرات الحرجة ضمن SLA: المؤشر

(عدد الثغرات الحرجة المغلقة ضمن SLA ÷ إجمالي الثغرات الحرجة) × 100 :الصيغة
منصة إدارة الثغرات :مصدر البيانات

نسبة محاولات الدخول الفاشلة الشاذة
نسبة محاولات الدخول الفاشلة الشاذة :المؤشر
(عدد المحاولات الشاذة المكتشفة ÷ إجمالي محاولات الدخول) × 100 :الصيغة
مكتب CISO / نظام الحوكمة :مصدر البيانات

عدد حوادث تسرب البيانات الحرجة
عدد حوادث تسرب البيانات الحرجة :المؤشر
عدد حوادث تسرب البيانات الحرجة خلال الفترة :الصيغة
منصة SIEM / DLP :مصدر البيانات

نسبة تغطية التشفير للبيانات الحساسة
نسبة تغطية التشفير للبيانات الحساسة :المؤشر
(عدد الأصول أو البيانات الحساسة المحمية بالتشفير و DLP ÷ إجمالي الأصول أو البيانات الحساسة المستهدفة) × 100 :الصيغة
منصة التشفير / DLP / منصة تصنيف البيانات :مصدر البيانات

درجة مخاطر الأطراف الثالثة
درجة مخاطر الأطراف الثالثة :المؤشر
(عدد البنود المنجزة ÷ إجمالي البنود المخططة) × 100 :الصيغة
مكتب CISO / نظام الحوكمة :مصدر البيانات

نسبة الأصول المصنفة وفق ضوابط البيانات
نسبة الأصول المصنفة وفق ضوابط البيانات :المؤشر
(عدد الضوابط المحققة ÷ إجمالي الضوابط المستهدفة) × 100 :الصيغة
منصة الحوكمة وقياس الامتثال :مصدر البيانات

معدل فشل اختبارات التصيد الاحتيالي
معدل فشل اختبارات التصيد الاحتيالي :المؤشر
(عدد الموظفين الذين فشلوا في اختبار التصيد ÷ إجمالي الموظفين المختبرين) × 100 :الصيغة
منصة محاكاة التصيد :مصدر البيانات

نسبة انعقاد لجنة حوكمة الأمن السيبراني وفق التواتر المعتمد
نسبة انعقاد لجنة حوكمة الأمن السيبراني وفق التواتر المعتمد :المؤشر
(عدد اجتماعات اللجنة المنعقدة ÷ إجمالي الاجتماعات المخططة) × 100 :الصيغة
مكتب CISO / نظام الحوكمة :مصدر البيانات

تقييم الثقة والمخاطر

درجة الثقة: 78%

تعكس هذه الدرجة مستوى النضج الأولي لل منظمة، حيث تغيب السياسات الموثقة لإدارة الثغرات الأمنية واستخبارات التهديدات، وتفتقر البيئة التشغيلية إلى عمليات SOC رسمية أو آليات استجابة للحوادث منظمة وفق متطلبات NCA ECC و NCA DCC. الفجوات الجوهرية تشمل غياب برنامج حوكمة موثق، وضعف منظومة التحكم في الوصول وإدارة الهوية، مما يشكل مساحة هجوم واسعة لم تعالج بعد.

اكتمال المدخلات

20% الوزن

4: الدرجة

15.6% المساهمة

تغطية الأطر المرجعية

20% الوزن

4: الدرجة

15.6% المساهمة

جدوى خارطة الطريق

20% الوزن

4: الدرجة

15.6% المساهمة

جاهزية الموارد

15% الوزن

4: الدرجة

11.7% المساهمة

نضج الحوكمة

15% الوزن

4: الدرجة

11.7% المساهمة

جاهزية حماية البيانات

10% الوزن

4: الدرجة

7.8% المساهمة

1	الحوكمة الرسمية لأمن المعلومات غياب سياسات	عالية	عال	ضوابط تقنية وإجراءات تشغيلية ومراقبة مستمرة	CISO
2	الوصول وغياب المصادقة متعددة العوامل ضعف التحكم في	عالية	عال	ضوابط تقنية وإجراءات تشغيلية ومراقبة مستمرة	وحدة إدارة الهوية والوصول رئيس
3	انعدام قدرة الكشف والاستجابة للحوادث	عالية	بالغ	ضوابط تقنية وإجراءات تشغيلية ومراقبة مستمرة	مركز العمليات الأمنية SOC مدير
4	التصيد الاحتيالي وبرمجيات الفدية التعرض لهجمات	عالية	بالغ	ضوابط تقنية وإجراءات تشغيلية ومراقبة مستمرة	قائد الحوكمة الأمنية
5	في بيئة الجهات الخارجية والموردين الثغرات الأمنية	متوسطة	عال	ضوابط تقنية وإجراءات تشغيلية ومراقبة مستمرة	CISO
6	غياب برنامج إدارة الثغرات الأمنية الدوري	متوسطة	عال	ضوابط تقنية وإجراءات تشغيلية ومراقبة مستمرة	مركز العمليات الأمنية SOC مدير

نموذج الحوكمة والمسؤوليات

اللجنة التوجيهية للأمن السيبراني
اعتماد استراتيجية الأمن السيبراني والإشراف على تنفيذها: نطاق المسؤولية
مسألة عن التوجه الاستراتيجي واعتماد السياسات والميزانيات: المساءلة
ترفع تقاريرها إلى الإدارة العليا ومجلس الإدارة: التقارير / التصعيد
الإطار المرتبط: NCA ECC / NCA DCC

رئيس الأمن السيبراني CISO
قيادة برنامج الأمن السيبراني وإدارة المخاطر السيبرانية: نطاق المسؤولية
مسألة عن تنفيذ الاستراتيجية والامتثال لـ NCA ECC و NCA DCC: المساءلة
يرفع التقارير إلى اللجنة التوجيهية والإدارة العليا: التقارير / التصعيد
الإطار المرتبط: NCA ECC / NCA DCC

مدير حوكمة الأمن السيبراني
إدارة السياسات والمعايير ومتابعة الامتثال التنظيمي: نطاق المسؤولية
مسألة عن تطوير وتحديث سياسات الأمن السيبراني: المساءلة
يرفع التقارير إلى CISO: التقارير / التصعيد
الإطار المرتبط: NCA ECC

مدير مركز العمليات الأمنية SOC
إدارة SOC والمراقبة المستمرة للتهديدات وتنفيذ SIEM: نطاق المسؤولية
مسألة عن كشف الحوادث الأمنية وزمن الاستجابة الأولية: المساءلة
يرفع التقارير إلى CISO ويصعد الحوادث الحرجة فوراً: التقارير / التصعيد
الإطار المرتبط: NCA ECC

مدير حماية البيانات
إدارة DLP والتشفير وتصنيف البيانات وحمايتها: نطاق المسؤولية
مسألة عن تطبيق ضوابط حماية البيانات الحساسة: المساءلة
يرفع التقارير إلى CISO ويصعد حوادث تسرب البيانات: التقارير / التصعيد
الإطار المرتبط: NCA DCC

مدير إدارة الهوية والوصول IAM/PAM
إدارة الهويات والصلاحيات وتنفيذ MFA للوصول المميز: نطاق المسؤولية
مسألة عن منع الوصول غير المصرح وإدارة الحسابات المميزة: المساءلة
يرفع التقارير إلى CISO: التقارير / التصعيد
الإطار المرتبط: NCA ECC

مدير الاستجابة للحوادث CSIRT
قيادة فريق CSIRT وتنفيذ خطة الاستجابة للحوادث: نطاق المسؤولية
مسألة عن احتواء الحوادث وإدارتها حتى الإغلاق: المساءلة
يرفع التقارير إلى CISO ويصعد الحوادث ذات الأثر العالي: التقارير / التصعيد
الإطار المرتبط: NCA ECC

مدير إدارة الثغرات
إدارة برنامج إدارة الثغرات وفحصها ومعالجتها وفق SLA: نطاق المسؤولية
مسألة عن معالجة الثغرات الحرجة خلال SLA المحدد: المساءلة
يرفع التقارير إلى CISO: التقارير / التصعيد
الإطار المرتبط: NCA ECC

مدير استمرارية الأعمال / التعافي
إدارة استمرارية الأعمال والتعافي من الكوارث السيبرانية: نطاق المسؤولية
مسائل عن تنفيذ خطط BCP / DRP السيبرانية واختبارها: المساءلة
يرفع التقارير إلى CISO والإدارة العليا: التقارير / التصعيد
الإطار المرتبط: NCA ECC

مكتب إدارة المشاريع PMO
متابعة تنفيذ خارطة الطريق والمبادرات السيبرانية: نطاق المسؤولية
مسائل عن تتبع الإنجاز والمخاطر والتصعيد: المساءلة
يرفع التقارير إلى CISO واللجنة التوجيهية: التقارير / التصعيد
الإطار المرتبط: NCA ECC / NCA DCC

الإدارة العليا
الإشراف التنفيذي ورفع المخاطر السيبرانية إلى مجلس الإدارة: نطاق المسؤولية
مسألة عن دعم الموارد واتخاذ القرارات الاستراتيجية: المساءلة
ترفع التقارير إلى مجلس الإدارة: التقارير / التصعيد
الإطار المرتبط: NCA ECC / NCA DCC

مصفوفة تتبع الأطر المرجعية

NCA DCC (Data Cybersecurity Controls)
NCA DCC (Data Cybersecurity Controls)
الفجوة مجال القدرة الإطار المرجعي
NCA DCC (Data Cybersecurity Controls)
تصنيف البيانات: مجال القدرة
إعداد الإطار التنظيمي لحوكمة الأمن السبراني يشمل السياسة العامة وسياسات فرعية تغطي متطلبات NCA ECC-1-1 كالتصنيف والمخاطر والامتثال: الفجوة
NCA DCC (Data Cybersecurity Controls)
التشفير: مجال القدرة
ضعف ضوابط التشفير وإدارة المفاتيح: الفجوة
NCA DCC (Data Cybersecurity Controls)
منع تسرب البيانات / DLP: مجال القدرة
ضعف ضوابط منع تسرب البيانات: الفجوة
NCA DCC (Data Cybersecurity Controls)
معالجة البيانات الحساسة: مجال القدرة
ضعف معالجة البيانات الحساسة: الفجوة
NCA DCC (Data Cybersecurity Controls)
حماية البيانات: مجال القدرة
نشر حلول لمنع فقدان البيانات DLP على نقاط النهاية والبريد الإلكتروني وبوابات الإنترنت لحماية البيانات الحكومية الحساسة وفق متطلبات NCA: الفجوة
وضبط قواعد التصنيف DCC
NCA DCC (Data Cybersecurity Controls)
NCA DCC (Data Cybersecurity Controls)
المخاطر المؤشر المبادرة الإطار
NCA DCC (Data Cybersecurity Controls)
تنفيذ تصنيف البيانات / تصنيف البيانات الحساسة: المبادرة
نسبة تصنيف البيانات الحساسة: المؤشر
اختراق البيانات أو سوء تصنيف البيانات الحساسة: المخاطر
NCA DCC (Data Cybersecurity Controls)
تطبيق ضوابط التشفير: المبادرة
نسبة الامتثال لسياسات التشفير: المؤشر
تسرب البيانات أثناء النقل أو التخزين: المخاطر
NCA DCC (Data Cybersecurity Controls)
تطبيق DLP / منع تسرب البيانات: المبادرة
عدد حوادث تسرب البيانات أو مؤشرات منع التسرب: المؤشر
فقدان البيانات الحساسة: المخاطر
NCA DCC (Data Cybersecurity Controls)
معالجة البيانات الحساسة وفق الضوابط: المبادرة
نسبة الأصول الحساسة المصنفة أو المحمية: المؤشر
إفشاء غير مصرح للبيانات الحساسة: المخاطر
NCA DCC (Data Cybersecurity Controls)
حماية البيانات أثناء النقل والتخزين: المبادرة
نسبة الأصول المشفرة أو المحمية: المؤشر

اختراق البيانات أو ضعف حماية البيانات: المخاطر

NCA ECC (Essential Cybersecurity Controls)

NCA ECC (Essential Cybersecurity Controls)

الفجوة | مجال القدرة | الإطار المرجعي

NCA ECC (Essential Cybersecurity Controls)

حوكمة الأمن السيبراني: مجال القدرة

غياب وظيفة CISO وهيكل حوكمة الأمن السيبراني: الفجوة

NCA ECC (Essential Cybersecurity Controls)

إدارة الهوية والوصول: مجال القدرة

قصور إدارة الهوية والوصول IAM وغياب المصادقة متعددة العوامل MFA: الفجوة

NCA ECC (Essential Cybersecurity Controls)

الرصد الأمني (SOC / SIEM): مجال القدرة

غياب مركز العمليات الأمنية SOC وأدوات SIEM: الفجوة

NCA ECC (Essential Cybersecurity Controls)

الاستجابة للحوادث: مجال القدرة

غياب مركز العمليات الأمنية SOC وأدوات SIEM: الفجوة

NCA ECC (Essential Cybersecurity Controls)

إدارة الثغرات: مجال القدرة

ضعف إدارة الثغرات الأمنية وغياب منع تسرب البيانات DLP وضوابط الوصول عن البعد: الفجوة

NCA ECC (Essential Cybersecurity Controls)

NCA ECC (Essential Cybersecurity Controls)

المخاطر | المؤشر | المبادرة | الإطار

NCA ECC (Essential Cybersecurity Controls)

تأسيس إدارة الأمن السيبراني وتشكيل لجنة حوكمة الأمن السيبراني: المبادرة

نسبة اكتمال الهيكل التنظيمي والسياسات المعتمدة: المؤشر

ضعف الحوكمة أو غياب المساءلة السيبرانية: المخاطر

NCA ECC (Essential Cybersecurity Controls)

تطبيق IAM/PAM/MFA: المبادرة

نسبة تطبيق المصادقة متعددة العوامل MFA للوصول المميز: المؤشر

اختراق أنظمة التحكم في الوصول والهوية: المخاطر

NCA ECC (Essential Cybersecurity Controls)

تأسيس مركز العمليات الأمنية SOC وتنشيط SIEM: المبادرة

متوسط زمن كشف الحوادث الأمنية الحرجة: المؤشر

فشل آليات الكشف المبكر للتهديدات المتقدمة: المخاطر

NCA ECC (Essential Cybersecurity Controls)

تأسيس فريق CSIRT وتطوير خطة الاستجابة للحوادث: المبادرة

متوسط زمن الاستجابة للحوادث الحرجة: المؤشر

تأخر احتواء الحوادث أو ضعف الاستجابة للحوادث: المخاطر

NCA ECC (Essential Cybersecurity Controls)

تنفيذ برنامج إدارة الثغرات الأمنية وفحص الثغرات: المبادرة

نسبة الثغرات الحرجة المعالجة خلال SLA المحدد: المؤشر

استغلال الثغرات الحرجة في الأنظمة الحكومية: المخاطر

الملاحق

الملحق أ — الأطر المرجعية

الأطر المرجعية المستخدمة في إعداد هذه الوثيقة:

- ECC: NCA ECC (Essential Cybersecurity Controls)
- DCC: NCA DCC (Data Cybersecurity Controls)

الملحق ب — قاموس المصطلحات

تعريفات المصطلحات والاختصارات المستخدمة في هذه الوثيقة:

- (NCA) الضوابط الأساسية للأمن السيبراني: ECC
- (NCA) ضوابط الأمن السيبراني للبيانات: DCC
- المصادقة متعددة العوامل: MFA
- الشبكة الافتراضية الخاصة: VPN
- إدارة الهوية والوصول: IAM
- إدارة الوصول المميز: PAM
- مركز العمليات الأمنية: SOC
- إدارة المعلومات والأحداث الأمنية: SIEM
- فريق الاستجابة لحوادث الأمن السيبراني: CSIRT
- منع تسرب البيانات: DLP
- مؤشر المخاطر الرئيسي: KRI
- تصنيف البيانات: Data Classification
- كشف التهديدات والاستجابة في النقاط الطرفية: EDR
- مؤشر الأداء الرئيسي: KPI